

INSTITUTO POLITÉCNICO NACIONAL
CENTRO DE INVESTIGACIÓN EN COMPUTACIÓN
Laboratorio de Ciberseguridad

Nombre del Alumn@: Guevara Badillo Areli Alejandra **BOLETA:** 2023630157

Unidad Académica: Escuela Superior de Cómputo **Fecha de entrega:** 05/11/2025

Actividad 2: Análisis de archivo Log para la detección de intrusos

Instrucciones:

- 1) Lee con atención la sección “**Introducción**” del presente documento.
- 2) Contesta las siguientes preguntas:
 - a. ¿A qué se refiere el término baseline?
Se refiere a conocer el estado y comportamiento normal de un sistema o una red.
 - b. ¿Qué implica una política de retención de Log?
Tener reglas definidas sobre cómo y por cuánto tiempo se deben almacenar los logs y todos los "artefactos" (evidencias) capturados durante un incidente.
 - c. ¿Por qué es importante conocer o determinar la sincronización de relojes entre los sistemas para el análisis de un escenario de riesgo?
Para poder construir una línea de tiempo completa y precisa del incidente. Si los relojes de los diferentes sistemas no están sincronizados, sería imposible saber en qué orden ocurrieron realmente los eventos, lo que complica o imposibilita el análisis del ataque.
 - d. ¿Por qué es importante contar con la línea de tiempo completa del incidente?
Porque se usa como base para analizar la respuesta al incidente y resolver preguntas claves como quien encontró el problema, si se realizó la evaluación inicial de manera correcta, que se puede mejorar y cuanto tiempo se tardó en resolverlo.
- 3) Tomando en cuenta la información de la sección “Introducción”, realiza la actividad definida en la sección “Análisis de log”.

1. INTRODUCCIÓN

“No es posible determinar qué es anormal si no se conoce lo que es normal.”

Para mitigar escenarios de riesgo o ataque se debe asegurar tener:

- Perfil del sistema
- Perfil de la red / baseline
- La política de retención de Log
- Sincronización de relojes entre todos los sistemas.

Un incidente no está terminado cuando el incidente se resuelve. Cuando un incidente se cierra totalmente, será documentado, y esta documentación debe ser muy detallada:

- la línea de tiempo completa del incidente,
- los pasos que fueron tomados para resolver el problema,
- lo que sucedió durante cada paso,
- cómo los problemas fueron finalmente resueltos en profundidad.

INSTITUTO POLITÉCNICO NACIONAL
CENTRO DE INVESTIGACIÓN EN COMPUTACIÓN
Laboratorio de Ciberseguridad

Este documento será empleado como base para contestar las siguientes preguntas:

¿Quién identifico el problema de seguridad? ¿Un usuario o el sistema de detección?

¿El incidente fue abierto con la prioridad correcta?

¿El equipo de seguridad de operaciones realizo la evaluación inicial de forma correcta?

¿Hay algo que puede ser mejorado en este momento?

¿El análisis de datos se realizó correctamente?

¿La contención se realizó correctamente?

¿Existe algo que puede ser mejorado en este punto?

¿Cuánto tiempo tomó resolver este incidente?

Otro punto importante es la retención de evidencias. Todos los artefactos que fueron capturados durante el incidente deben ser almacenados de acuerdo con las políticas de retención de la empresa, a excepción de que exista una especificación que la empresa deba cumplir por parte del gobierno u otras entidades reguladoras.

1.1. Defensa de red de cómputo basado en Inteligencia (Intelligent-Driven Computer Network Defense [1])

Elemento fundamental de inteligencia en este modelo es el “indicador”. Un indicador es cualquier pieza de información que de forma objetiva describe una intrusión. Los indicadores pueden ser subdivididos en tres tipos:

Atómicos: Son aquellos que no pueden ser descompuestos en partes más pequeñas y retener su significado en el contexto de una intrusión. Ejemplos típicos son las direcciones IP, las cuentas de correo y los identificadores de vulnerabilidades.

Por cómputo (Computed): Son los indicadores que se derivan a partir de los datos involucrados en el incidente de seguridad. Entre estos indicadores se encuentran los valores hash y los obtenidos mediante el uso de expresiones regulares.

Comportamiento (Behavioral): Son colecciones de indicadores por cómputo y atómicos, usualmente sujetos a la una evaluación cualitativa en función de su cantidad y posiblemente por lógica combinacional. Un ejemplo puede ser la sentencia: **“el intruso pudo haber empleado inicialmente un backdoor con el cual generó tráfico de red que coincide con *[expresión regular]* a una razón de *[algún valor de frecuencia]* para *[alguna dirección IP]*, y entonces remplazarlo con un tráfico que coincide con el valor hash MD5 *[valor]* una vez que el acceso fue establecido “.**

Referencias:

- [1] <https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/LM- White-Paper-Intel-Driven-Defense.pdf>

2. ANÁLISIS DE LOG

Se considera un sistema de distribución de energía eléctrica conformado por un conjunto de subestaciones, las cuales tienen una arquitectura de red como la mostrada en la figura 1, para el cual se han reportado incidentes de falla en la operación por parte del administrador de infraestructura crítica de la empresa. Como parte inicial de la atención del ataque, se ha identificado que el grupo atacante ha logrado conectar un dispositivo no autorizado a una red de subestación, permitiéndoles conectarse al servidor de control del sistema para manipular la potencia de salida de la estación.

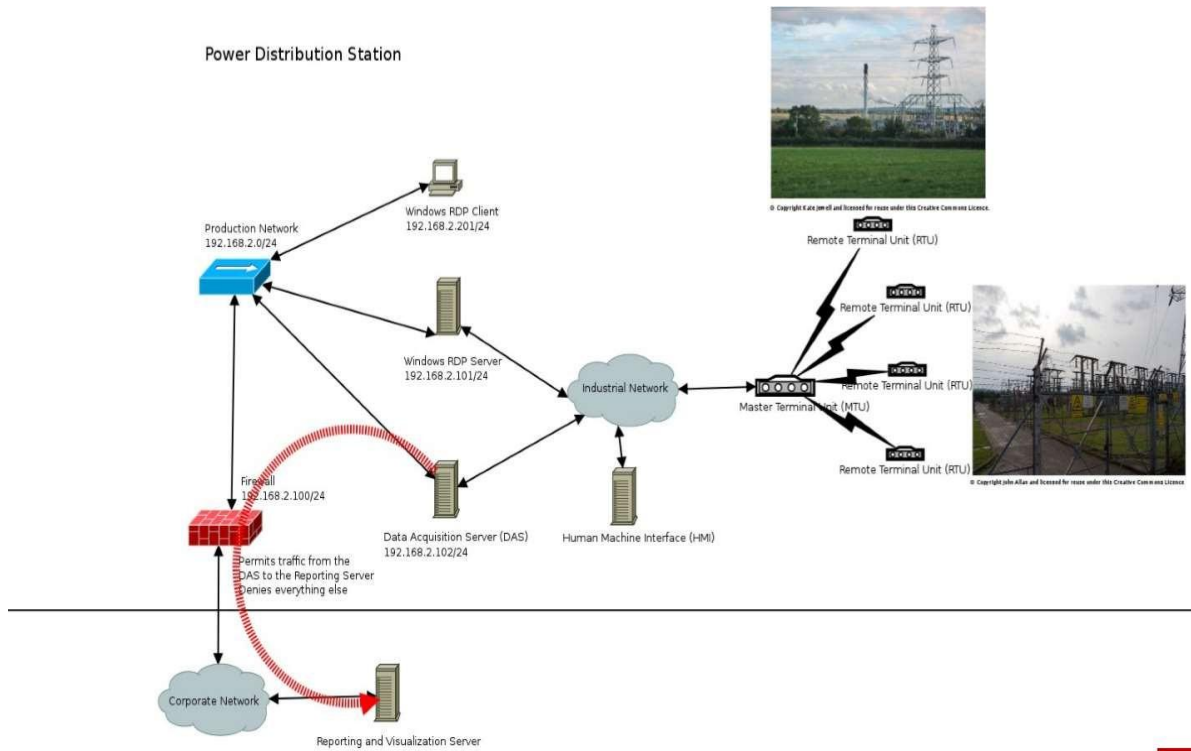


Figura 1. Arquitectura de red de las subestaciones que integran el sistema de distribución eléctrica.

1) Con base en la arquitectura del sistema, ver figura 1, completa la siguiente tabla

Dispositivo	Descripción (Función)	IP
Windows RDP Client	Es la computadora (cliente) que usa un operador para conectarse y controlar el servidor de forma remota.	192.168.2.201 /24
Windows RDP Server	Es el servidor que recibe esas conexiones remotas. Es el punto de entrada para administrar la red.	192.168.2.101 /24
HMI	(nterfaz Humano-Máquina Es la pantalla o panel donde un operador puede ver y controlar en tiempo real lo que pasa en la subestación.	(No especificada)

INSTITUTO POLITÉCNICO NACIONAL
CENTRO DE INVESTIGACIÓN EN COMPUTACIÓN
Laboratorio de Ciberseguridad

Dispositivo	Descripción (Función)	IP
DAS	Servidor de Adquisición de Datos Es el servidor que recolecta los datos de todos los sensores y equipos de la red industrial.	192.168.2.102 /24
Reporting and Visualization Server	Es un servidor en la red de oficina que recibe los datos del DAS para generar gráficas y reportes a largo plazo.	(No especificada)
Production Network	Es la red local (LAN) principal de la subestación donde están todos los equipos de control.	192.168.2.0 /24
Firewall	Es el guardia de seguridad que filtra el tráfico entre la red de producción y la red corporativa. Solo deja pasar los datos del DAS y bloquea todo lo demás.	192.168.2.100 /24
Master Terminal Unit	Es el equipo maestro que controla y recibe información de las unidades (RTU) que están físicamente en el campo.	(No especificada)

Así mismo, se ha solicitado los logs del Terminal Server [2] al administrador de infraestructura crítica (scada-log.txt). Con base en esta información (arquitectura de red y archivo log del terminal server) proporciona datos que permitan identificar al dispositivo ajeno a la red y completa la siguiente tabla con la información obtenida.

En los logs de Windows, los eventos más relevantes para intrusión son:

EventID	Descripción
4624	Inicio de sesión exitoso
4625	Inicio de sesión fallido
4720	Creación de cuenta de usuario
4728	Usuario añadido a grupo privilegiado
4647	Cierre de sesión
4672	Asignación de privilegios especiales
4907	Cambio en la política de auditoría

Método de Análisis:

1. Buscamos en el log eventos de inicio de sesión exitoso (Event-ID 4624).
2. Filtramos estos eventos por el Tipo de Anmelde (LogonType) 10, que corresponde a una conexión remota (RemoteInteractive), como RDP, lo cual es inusual en un sistema SCADA.
3. Comparamos la dirección IP de origen (netzwerkadresse) de esos inicios de sesión con los dispositivos *legítimos* del diagrama.

INSTITUTO POLITÉCNICO NACIONAL
CENTRO DE INVESTIGACIÓN EN COMPUTACIÓN
Laboratorio de Ciberseguridad

Resultados del Análisis del Log:

Encontramos un inicio de sesión exitoso (Evento 4624) para user1 con LogonType 10 de una IP no reconocida ya que no existe en nuestro diagrama de la red **192.168.2.187**.

```
1 <EventID>4624</EventID>
2 ...
3 <Data Name="TargetUserName">user1</Data>
4 <Data Name="LogonType">10</Data>
5 <TimeCreated SystemTime="2012-07-04T11:43:26.015625000Z" />
6 ...
7 <Data Name="IpAddress">192.168.2.187</Data>
```

Encontramos EventID 4720 (creación de usuario) para el user1:

```
1 <EventID>4720</EventID>
2 ...
3 <TimeCreated SystemTime="2012-07-04T10:57:00.234375000Z" />
4 ...
5 <Data Name="TargetUserName">user1</Data>
6 <Data Name="TargetDomainName">WIN-KJHGCUABASL</Data>
7 ...
8 <Data Name="SubjectUserName">Administrator</Data>
```

Aparece que el usuario Administrador creo el user1.

Buscamos el inicio de sesión del administrador antes de esa fecha de creación de usuario.

```
1 <EventID>4624</EventID>
2 ...
3 <TimeCreated SystemTime="2012-07-04T10:47:51.125000000Z" />
4 ...
5 <Data Name="TargetUserName">Administrator</Data>
6 <Data Name="TargetDomainName">WIN-KJHGCUABASL</Data>
7 ...
8 <Data Name="IpAddress">192.168.2.187</Data>
```

Aquí podemos observar como el administrador ingreso a las 10:47hrs (antes de la creación de user1 que fue a las 10:57hrs, 10 minutos antes) y que proviene de la misma IP: **192.168.2.187**.

Por lo que podemos concluir que el acceso no autorizado es por parte del dispositivo que posee esa dirección IP

INSTITUTO POLITÉCNICO NACIONAL
CENTRO DE INVESTIGACIÓN EN COMPUTACIÓN
Laboratorio de Ciberseguridad

y nuestra línea de tiempo del ataque quedaría de la siguiente manera:

- **12 : 47 : 51 (UTC 10:47:51):** primer inicio de sesión del atacante. El Evento 4624 (inicio de sesión exitoso) muestra que la cuenta `Administrator` se conectó desde la IP anómala `192.168.2.187`.
- **12 : 57 : 00 (UTC 10:57:00):** 10 minutos después, el Evento 4720 (Creación de cuenta de usuario). El log confirma que `Administrator` (el atacante) creó la nueva cuenta `user1`.
- **13 : 42 : 40 (UTC 11:42:40):** El atacante vuelve a conectarse. El Evento 4624 (inicio de sesión exitoso) muestra que la cuenta `user1` (recién creada) inició sesión desde la misma IP atacante `192.168.2.187`

Dispositivo del atacante:	El dispositivo no autorizado es el que tiene la dirección IP <code>192.168.2.187</code>
---------------------------	---

TIPS:

- El archivo log [3] se encuentra en formato texto (.txt) por lo cual es posible su lectura con el uso de un editor simple de texto plano (Por ejemplo, Notepad).
- Los archivos log suelen tener formatos distintos de acuerdo con el fabricante, por lo que para su interpretación es conveniente consultar la documentación del fabricante (por ejemplo, documentación del evento 4624, ver [4]).
 - Se sugiere revisar los tags contenidos dentro del tag `<EventData>` para identificar una o varias cadenas que ayuden al parsing del archivo log e identificar la información del dispositivo atacante.
- En sistemas Windows modernos, es posible emplear el comando ***findstr*** de la consola de comandos (cmd) para filtrar (parsing) el contenido de un archivo de texto.
- En sistemas Linux se suele emplear el comando ***grep*** para el parsing de archivos de texto.

Referencias:

- [2] <https://www.parallels.com/blogs/ras/what-is-a-terminal-server/>
- [3] <https://sysadminpoint.com/2020/07/13/how-to-view-rdp-connection-logs-in-windows/>
- [4] <https://docs.microsoft.com/en-us/windows/security/threat-protection/auditing/event-4624>